



Nationales Referenzprojekt IT-Sicherheit in Industrie 4.0



Projektergebnisse

Inhalt

Anwendungsfall „Visueller Security-Leitstand“	3
Executive Summary	3
Problemstellung und Handlungsbedarf	3
Bedrohungs- und Risikoanalyse	6
Gesamtarchitektur	9
Lösungsansätze	12
Visualisierung im Security-Leitstand	25
Dezentrale Datenverteilung	26
Ausblick	28
Referenzen	30

Autoren des Dokuments:

Simon Duque Antón (DFKI)

Mohammad Reza Norouzian (TUM)

Kai Fischer, Daniela Friedrich, Prabhakaran Kasinathan (Siemens AG)

Stephan Teuber, Ricardo Hormann (Volkswagen AG)

Markus Soppa (accesssec GmbH)

Sinisa Dukanovic, Julien Hachenberger (Fraunhofer SIT)

Alexander Giehl, Sven Plaga, Stefan Tatschner, Norbert Wiedermann (Fraunhofer AISEC)

Anwendungsfall „Visueller Security-Leitstand“

Was in der Office-IT schon längst alltäglich ist, findet im Fertigungsumfeld noch selten Anwendung: Der Einsatz eines Security-Leitstandes, der einen aktuellen Überblick über den Stand der Informationssicherheit abbildet. Gerade in der Industrie könnten entsprechend angepasste Lösungen aber einen erheblichen Beitrag für eine sichere Produktion leisten.

Executive Summary

Im Teilprojekt ‚Visueller Security-Leitstand‘ wird im Rahmen von IUNO die Konzeption und Entwicklung eines Security-Leitstands für die Produktion erforscht. Mit anderen Worten: Es geht darum, Datenströme in der Produktion in Echtzeit zu erfassen und darauf basierend relevante Daten über den aktuellen Stand der Informationssicherheit ganzheitlich und übersichtlich abzubilden. Abweichungen in der Produktion können damit sofort sichtbar werden und die Teilnehmer eines Produktionsnetzes sind transparent sowie eindeutig identifizierbar. Unternehmen werden somit in die Lage versetzt, zu jedem Zeitpunkt schnell und effizient in den Prozess einzugreifen bevor der Produktionsprozess zum Stehen kommt.

Nach dem heutigen Stand der Technik ist die Erfassung, Analyse und Übermittlung von benötigten sicherheitsrelevanten Daten mit verschiedenen Kommunikationspartnern eines Produktionsnetzes allerdings oft sehr komplex. Um dieser Problematik zu begegnen, entwickeln die IUNO-Partner Werkzeuge, die in der Lage sind, entsprechende Daten zu erheben und etwaige Angriffe zu erkennen. Parallel entsteht eine Visualisierungskomponente, die den „Echtzeit“-Status auf Basis der getesteten Werkzeuge darstellt und bewertet.

Kommt es zu Abweichungen im Produktionsablauf, ist der Leitstand in der Lage, Fehlkommandos oder fremde Eindringlinge im Unternehmensnetz zu erkennen. In einer Versuchsumgebung wurde dies anhand einer Reihe von exemplarischen Angriffen evaluiert. Dem Menschen kommt trotz der vielen automatisierten Prozesse eine tragende Rolle zu. Denn am Ende wird es seine Aufgabe sein, die Meldungen und Alarmer der Erkennungstools im Leitstand richtig zu deuten, um schnell in den Prozess eingreifen zu können.

Problemstellung und Handlungsbedarf

Was sind bei diesem Anwendungsfall die Herausforderungen?

Zuallererst erfordert der Aufbau eines „Visuellen Security-Leitstands“ für die Produktion ein dediziertes Industrie 4.0 Fertigungsszenario. Dies ist notwendig, damit die korrekte Übermittlung und Darstellung von Sicherheitsinformationen, wie z.B. Alarmer, Ereignisse und Nachrichten, stattfinden kann. Die aktuellen Herausforderungen liegen zumeist in der Schwierigkeit, bestehende Office- oder gar dedizierte Lösungen für die Produktion zu nutzen. Die derzeit am Markt bestehenden Lösungen bilden nicht immer die Bedürfnisse der Unternehmen und die spezifischen Gegebenheiten der Produktion ab. Des Weiteren kommt hinzu, dass die Produktions-IT und das Know-how in den jeweiligen Unternehmen stark variiert, was die Integration und Abstimmung eines Visuellen Security-Leitstands erschwert. Gerade bei KMUs sind fehlende ganzheitliche Ansätze und eine IT-(Sicherheit)-Strategie zu vermerken.

Wo liegt der Forschungsbedarf?

In der Office-IT gehören Leitstände zu zentralen Komponenten der IT-Sicherheit, die eine Evaluierung der IT-Sicherheitslage ermöglichen. Dabei wird durch konsequente Verwaltung von Zugriffsberechtigungen und Überwachung eine kontinuierliche Analyse des Netzwerkverkehrs ermöglicht. Auf diese Weise ist es möglich, Angriffe von außen zu detektieren und darauf gezielt zu reagieren. Dies geschieht unter Zuhilfenahme automatisiert arbeitender Werkzeuge im Bereich Security Information and Event Management (SIEM), Anomalieerkennung, Identity and Access Management (IAM) und Integritätsüberwachung. Derzeit sind diese „Office-Bausteine“ nur teilweise im Produktionsfeld integrierbar.

Mit dem zunehmenden Einzug von Industrie 4.0 und dem Entstehen neuer Geschäftsmodelle nehmen auch die Anforderungen an die Automatisierung, Individualisierung und Flexibilität stark zu. Damit geht auch einher, dass die Komplexität in Produktionsstätten zunimmt, da immer mehr vernetzte, automatisierte und kommunizierende Komponenten mit entsprechenden Schnittstellen eingesetzt werden. Dies hat enorme Auswirkungen auf die Angriffsfläche der vollvernetzten Produktion. Nicht nur sind die Einfallstore mehr und vielfältiger (Wahrscheinlichkeit), sondern insbesondere das Schadensausmaß (Schadensschwere) erreicht ein höheres, gar existenzbedrohendes, Ausmaß. Daher ist es unabdingbar Angriffe zu erkennen und zu reagieren zu können, um das Schadensausmaß gering zu halten. Eine kontinuierliche Sicherheitsüberwachung, wie sie bereits in der Office-IT möglich ist, kann einen wichtigen Schritt hierfür darstellen und muss auch in den Produktionsstätten Einzug halten. Bei der Erfassung und Darstellbarkeit sicherheitsrelevanter Meldungen für die Produktion an einem Leitstand, sowie bei der Übertragbarkeit der Informationen auf andere Endgeräte und menschengerechten Interpretationsform, ist jedoch noch ein Forschungsbedarf wahrzunehmen, um größtmögliche Transparenz über die aktuelle Sicherheitslage bieten zu können.

Warum ist IT-Sicherheit hier ein entscheidender Faktor?

Grundsätzlich ist zu sagen, dass eine 100%ige Sicherheit nicht erreicht werden kann. Im Wesentlichen ist IT-Sicherheit ein Erfolgsgarant für die Vision von Industrie 4.0 und die daraus neu entstehenden Geschäftsmodelle. Ein ganzheitlicher Ansatz ist unabdingbar, um die IT-Sicherheitsrisiken erfassen, bewerten, reduzieren und detektieren zu können. Die Entwicklung und Implementierung eines Security-Leitstands dient dabei der Steigerung der gesamtheitlichen IT-Sicherheit in der Produktion, sowie der Detektion von Anomalien bzw. Abweichungen von „Normalzustand“. Der Security-Leitstand dient daher der Bekämpfung erkannter Angriffe auf Produktions- bzw. Unternehmensnetzwerke. Außerdem sind Maßnahmen zu koordinieren, die gemäß der Prozesse des IT-Sicherheitsmanagementsystems definiert sind. Erfolgreich behandelte Vorfälle sollten dabei dokumentiert werden, um im Wiederholungsfall schneller handlungsfähig zu sein.

Warum reichen bisherige Ansätze nicht aus?

Um zu verstehen, weshalb bisherige Ansätze zu IT-Sicherheitsleitständen nicht ausreichend sind, ist es zunächst wichtig zu wissen, dass unterschiedliche Formen von Leitständen existieren. So bestehen beispielweise Leitstände, die zur Überwachung des Netzwerks bzw. einzelner Server eingesetzt werden. Diese steuern in erster Linie den kontinuierlichen Betrieb und führen Wartungsarbeiten durch. Dabei werden im Kern defekte Bauteile erkannt und ein Austausch angeordnet, als auch Überlastungen detektiert. Ereignisse die nicht innerhalb dieses vorgesehenen Spektrums liegen, weisen auf einen möglichen IT-Sicherheitsvorfall hin, sind aber nicht konkret für die Erfassung von IT-Sicherheitsvorfällen ausgelegt. Das Weiteren bestehen auch dedizierte IT-Sicherheits-Leitstände,

welche sich im Anwendungsfall unterscheiden. Im Wesentlichen werden aber Informationen im Datenverkehr analysiert. Dabei wird auf Virens Scanner oder Firewalls zurückgegriffen, um eine Bewertung der Informationen vornehmen zu können. Zusätzlich werden Informationen über Logdateien und Meldungen herangezogen, um statistische Vorhersagen über definierte Bereiche vornehmen zu können.

Diese Ansätze sind vielversprechend, für Produktionsumgebungen jedoch teilweise nicht geeignet. Ein Security-Leitstand für Produktionsstätten sollte in erster Linie die Visualisierung der realen Betriebsabläufe, mit entsprechend kritischen und technischen Informationen, darstellen und auswerten können. Hier sind bestehende Ansätze nur zum Teil sinnvoll anwendbar bzw. ausgereift.

Was muss berücksichtigt werden, damit der Anwendungsfall funktioniert?

Im Kern des Vorhabens steht immer das definierte Fertigungsszenario. Dieses muss klar definiert und durchdacht sein. Dabei sind nicht nur die technischen Aspekte zu adressieren, sondern mindestens genauso wichtig ist die Zielgruppe des Anwendungsfalls. Im produktionsnahen Bereich sollten daher die Werks- und Produktionsleiter oder Meister im Wesentlichen berücksichtigt werden. Sie sind ein wesentlicher Erfolgsfaktor eines Security-Leitstands und müssen im Ernstfall schnellstmöglich reagieren können. Dafür muss die Darstellung für die Betriebsabläufe im Hinblick auf den Leitstand so umgesetzt werden, dass Ereignisse und Meldungen intuitiv und grafisch einfach für die Zielgruppe zu deuten sind.

Welche technischen Rahmenbedingungen bringt der Anwendungsfall mit sich?

Um den Anwendungsfall umsetzen zu können, sind große Mengen feingranularer Statusmeldungen der Produktionsumgebung zusammenzuführen. Erst auf Basis dieser Daten kann der Betriebszustand unterschiedlicher Anlagen abgebildet und eine Gesamtlage abgebildet werden.

Einzelne Daten über Status Rohmaterial, Werkzeug- und Maschinentemperatur, Taktrate, etc. geben einzelne Aufschlüsse über einen Normalbetrieb. Erst aber die Zusammenführung jener Daten und Meldungen lassen eine authentische Beurteilung des Zustandes zu. Auf diese Weise lassen sich zwar potenzielle Probleme der Anlagen abbilden, jedoch nicht die Erkennung von Angriffen auf die Produktion selbst. Daher ist der vorgesehene Leitstand um Security-Funktionen und -Werkzeuge, wie ein Security Information and Event Management (SIEM), eine Anomalieerkennung, ein Identity and Access Management (IAM) und eine Integritätsüberwachung, zu ergänzen.

Im Folgenden wird auf die Funktion und Notwendigkeit der Werkzeuge eingegangen.

- Das SIEM mit kann grundlegende Veränderungen im Netzwerk erkennen, indem es Daten sammelt, aufbereitet und bewertet, so dass Netzwerkänderungen im Hinblick auf Angriffe erkannt werden können.
- Bei einer Anomalieerkennung handelt es sich um sogenannte Intrusion Detection Systeme (IDS). Das System ermöglicht, aktiv Anomalien zu erkennen. Die Systeme unterscheiden sich in ihrem Anwendungsfeld (netzwerk- oder hostbasiert) und Verfahren (anomalie- oder signaturbasiert).
- Ein Identity and Access Management ist in der Office-IT weit verbreitet. Im Produktionsumfeld befinden sich Industriebetriebe noch in den Anfängen, durchdachte und funktionsfähige Ansätze umzusetzen, um Assets eine Identität zu verleihen und die dafür benötigte Verwaltung zu ermöglichen. IAM Systeme werden aber auch in der Produktion zunehmend die Rechteverwaltung von digitalen Konten übernehmen und eine kontinuierliche

Überwachung von Zugriffen über Accounts zulassen. Für eine „offene“ Produktionsumgebung und die Überwachung durch einen Sicherheitsleitstand sind dies elementare Bausteine, da hier zentral überwacht werden kann, wie Zugriffe auf Systeme und Anlagen erfolgen.

- Unter der Überwachung der Integrität in industriellen Automatisierungsanlagen kann die funktionale Unversehrtheit einer Menge von Geräten bzw. einem (Teil-) System verstanden werden. Die Voraussetzung für eine Überwachung einer Systemintegrität setzt Maßnahmen voraus, die in den einzelnen Komponenten des Systems realisiert sind. Dies kann aus Sicht von Stand der Technik nicht umfänglich gewährleistet werden. Zu großen Teilen bieten Industriekomponenten derzeit nicht entsprechende Security-Maßnahmen, um Integritätssicherheit und dessen Überwachung zu ermöglichen. Daher wird der Schutz der Integrität eines Systems aktuell durch (Netzwerk-)Zonenschutzkonzepte gewährleistet. Diese Zonen gilt es auf ihre Integrität hin zu überwachen.

Aus technischer Sicht ermöglichen nun einheitliche Kommunikationsprotokolle und Nachrichtenformate eine passive Überwachung der Integrität von Ethernet-basierten Feldbusnachrichten. Die Integrität der Nachrichten kann hierbei ständig durch Integrity-Sensoren ermittelt werden. Diese Sensoren nehmen an Hand von Filterkriterien den Datenverkehr zwischen industriellen Komponenten auf und berechnen kryptographische Integritätsreferenzwerte. Das Monitoring wirkt sich dabei nicht auf die Feldbusprotokolle aus und kann die Automatisierungsprozesse nicht beeinflussen. Die Integritätsreferenzwerte können nun übergeordnet, aufgrund der wechselseitigen Beziehung, geprüft werden. Sollte es nun zu Abweichungen im Produktionsprozess kommen, können fehlerhafte Kommandos oder Angriffe erkannt werden.

Bedrohungs- und Risikoanalyse

Um den Entwicklungsprozess bereits zu Beginn auf die Erfordernisse des Secure Software Engineering abzustimmen, wurde in einem sehr frühen Projektabschnitt eine kontinuierliche Bedrohungs- und Risikoanalyse angestoßen. Hierbei wurden zwei Verfahren angewendet.

Für eine erste Einschätzung wurde auf das **SDL Modeling Tool** [SDL-Tool] von Microsoft zurückgegriffen. Mit diesem wurden anhand der ersten Entwürfe für die Systemarchitektur die geplanten Teil-Systeme sowie deren Schnittstellen modelliert. Durch eine Segmentierung der einzelnen Teilbereiche des Demonstrators war es damit möglich Datenflüsse sowie Vertrauensbeziehungen zwischen den einzelnen interagierenden Teilbereichen zu definieren. Hierdurch konnte bereits in einer sehr frühen Phase des Projekts die Systemarchitektur im Hinblick auf die Sicherheitsaspekte Segmentierung und Modularität feingranuliert werden. Das grafische Ergebnis dieser Modellierung ist in Abbildung 1 wiedergegeben.

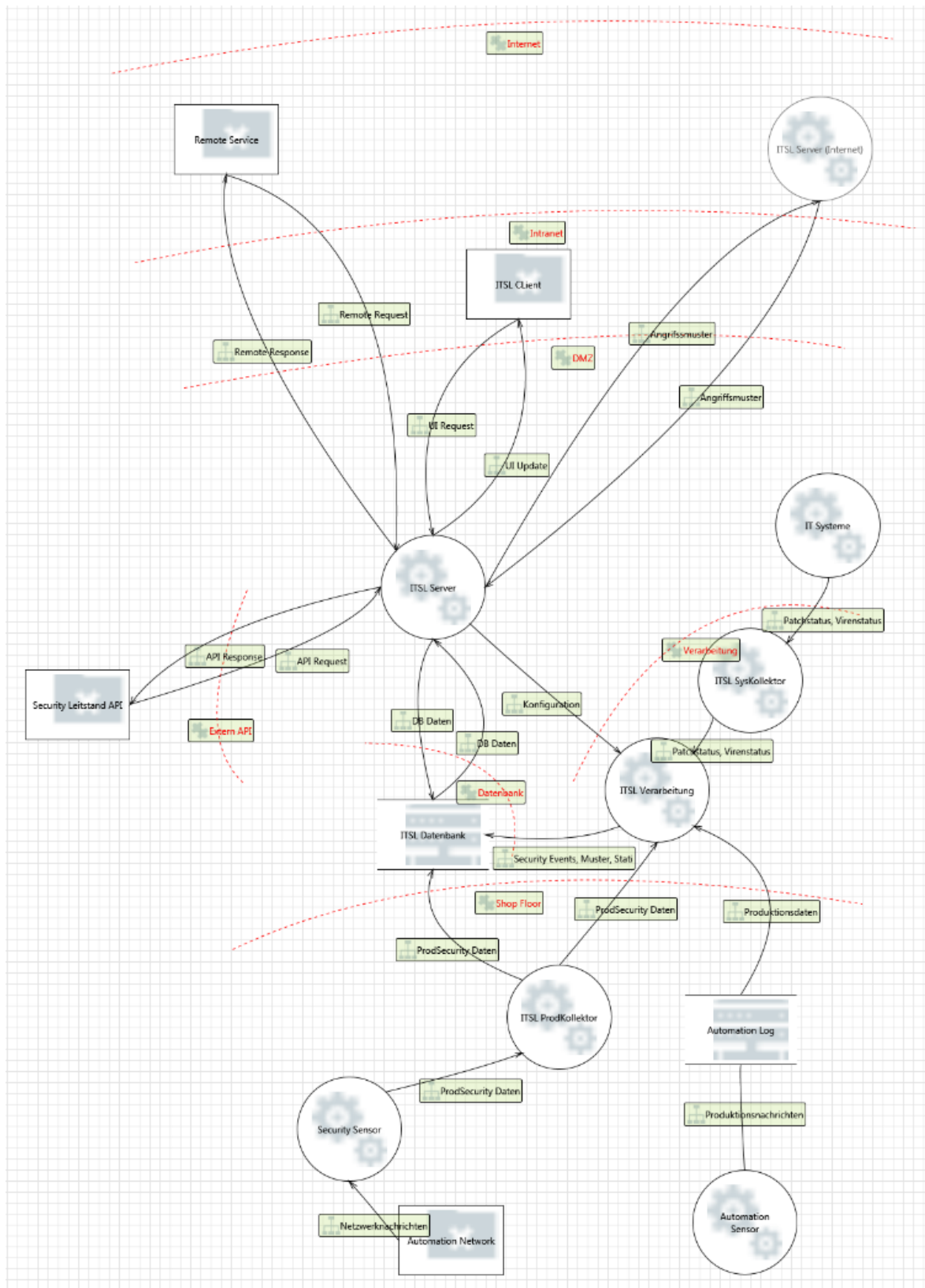


Abbildung 1: Modellierung Leitstandarchitektur in SDL

Um eine kontinuierliche Bewertung der Bedrohungen sowie vergleichbare Ergebnisse zu erhalten, wurde für den weiteren Verlauf auf im Rahmen von IUNO erarbeitete Vorgehensweise zur Risikoanalyse zurückgegriffen, welche im Wesentlichen die in Abbildung 2 gezeigten Aktivitäten umfasst.

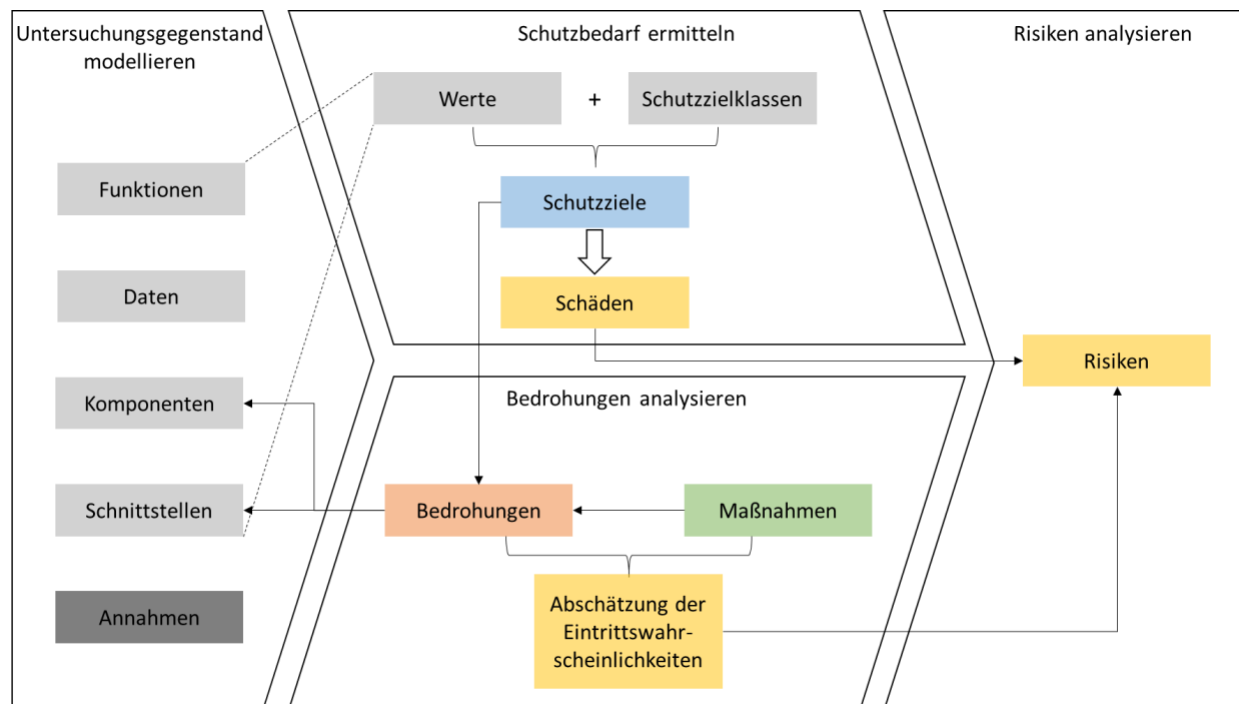


Abbildung 2: Hauptaktivitäten einer IUNO Bedrohungs- und Risikoanalyse

Hierbei wird zunächst der Untersuchungsgegenstand durch Security-Experten und Entwickler des zu untersuchenden Systems gemeinsam modelliert. Dieser Modellierungsschritt führt zu einem gemeinsamen Systemverständnis der verschiedenen Domänen-Experten und schafft eine Grundlage für eine weiterführende systematische Untersuchung der Security-Risiken. Für das modellierte System werden anschließend die Schutzziele ermittelt, indem für die modellierten Systemelemente alle relevanten Security-Attribute (wie z.B. Vertraulichkeit, Verfügbarkeit, oder Integrität) untersucht und die Schäden bei einer Verletzung dieser Schutzziele festgelegt werden. Hierfür wird auf einen Katalog möglicher Schäden zurückgegriffen, für die jeweils auch eine Schadenshöhe festgelegt ist. Weiterhin werden mögliche Bedrohungen auf das System identifiziert, indem Angriffe auf die Komponenten oder Schnittstellen des Systems systematisch untersucht werden. In diesem Zusammenhang werden auch vorhandene oder geplante Security-Maßnahmen mit einbezogen. Für jede Bedrohung wird zudem festgelegt, welche Schutzziele durch die jeweilige Bedrohung verletzt werden können. Eine Abschätzung der Wahrscheinlichkeit eines erfolgreichen Angriffs, beispielsweise basierend auf den benötigten Fähigkeiten eines Angreifers, ermöglicht schließlich die Abschätzung der Risiken. Im nächsten Schritt kann dann eine Risikobehandlung erfolgen, deren Wirksamkeit in einer iterativen Anpassung der Risikoanalyse untersucht werden kann.

Das IUNO-Verfahren wurde im Rahmen eines Kick-off Workshops eingeführt, in dem anhand der vorliegenden Architektur der Untersuchungsgegenstand modelliert wurde. Definitionslücken in der Architektur wurden initial mit Annahmen geschlossen. Um eine kontinuierliche Abgleich der Analyse mit dem Entwicklungsfortschritt zu ermöglichen, wurden mittels Microsoft Excel Tabellen erstellt, in denen sowohl Änderungen an der Architektur als auch die sich daraus ergebenden Ergebnisse kontinuierlich nachgepflegt wurden. Diese sind separat dokumentiert.

Für die Betrachtung des Risikos konnten für den Leitstand im Rahmen von IUNO keine belastbaren Aussagen getroffen werden. Das Risiko bestimmt sich aus Schaden X Eintrittswahrscheinlichkeit. Für die bislang eingesetzten Infrastrukturen in denen der Leitstand eingesetzt werden soll, ist das Paradigma von Sicherheit durch Isolation noch sehr vorherrschend. Daher war es im Rahmen des Projekts sehr schwer einen entsprechenden Schadenskatalog abzuleiten, der für eine angemessene Quantifizierung des Risikos geeignet schien. Für den Entwicklungsprozess des Leitstandes wurde die Definition des Schadenskatalogs aber als vernachlässigbar angesehen. Eine grobe Abschätzung des Risikos wurde daher über die Betrachtung der Eintrittswahrscheinlichkeit erreicht, die über das Angreifermodell sowie Expertenwissen modelliert wurde.

Im Endergebnis lassen sich aus den vorliegenden Analysen folgende Bedrohungen/Risiken ableiten:

Bedrohungen/Risiken für den Leitstand:

- Gefährdung der Vertraulichkeit der aufbereiteten Daten auf dem Client
- Gefährdung der Vertraulichkeit der aufbereiteten Daten auf dem Leitstand
- Gefährdung der Integrität der Angriffsmuster in der Datenbank
- Gefährdung der Authentizität der Sensordaten auf dem Leitstand und den Sensorknoten
- Störung der Verfügbarkeit der Leitstand-Datenbank mit den gespeicherten Angriffsmustern
- Störung der Verfügbarkeit der aufbereiteten Daten auf dem Transportweg zwischen Server und Client
- Störung der Verfügbarkeit der bestehenden Netze zwischen Leitstand und Sensorknoten

Bedrohungen/Risiken für die Infrastruktur/Unternehmensübergreifende Auswirkungen:

- Störung der Verfügbarkeit des Produktionsnetzes
- Störung der Verfügbarkeit der Unternehmens-IT
- Verlust von vertraulichen Daten durch erfolgreiche Angriffe
- Schädigung des Image durch Vertrauensverlust
- Gefährdung der Integrität von gefertigten Produkten durch Advanced Persistent Threats.

Gesamtarchitektur

Auf Basis der Risikoanalyse ist eine Architektur entstanden, die eine strikte Trennung des Produktionsnetzes von der Auswertung- und Analyseebene vorsieht. Dadurch wird technisch

sichergestellt, dass die in IUNO entstandenen Systeme rückwirkungsfrei arbeiten und die Produktion nicht durch eventuelles Fehlverhalten gestört werden kann.

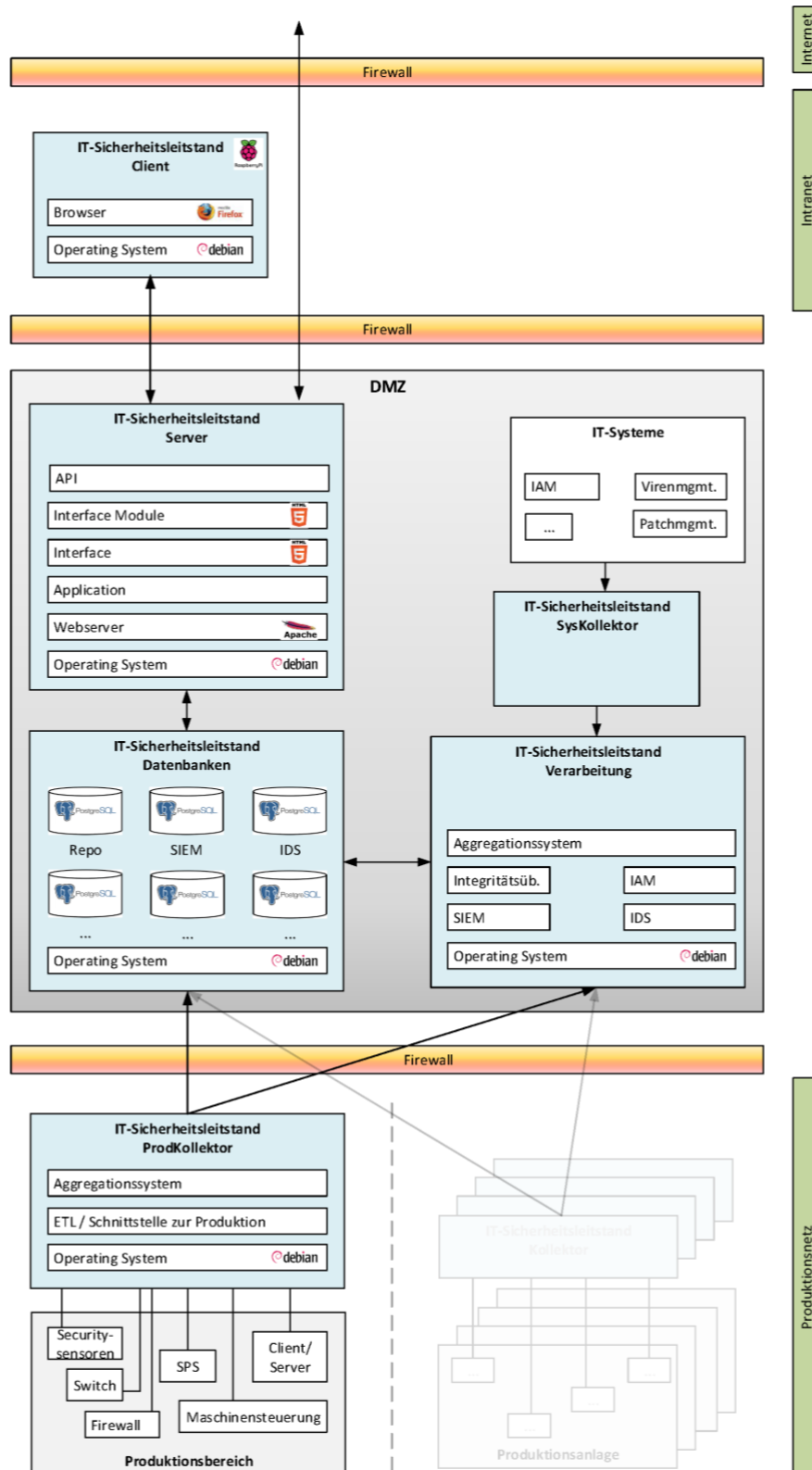


Abbildung 3: Architektur des Gesamtaufbaus

Diese Eigenschaft legt zugleich aber auch die Begrenzung des Gesamtsystems auf ein Intrusion Detection System fest. Anteile eines Intrusion Prevention Systems sind durch die Gesamtarchitektur ausgeschlossen. Abbildung 3 zeigt die Architektur mit den drei Hauptzonen „Produktion“, „DMZ/Verarbeitung“ und „Intranet“.

Lösungsansätze

Zur Erkennung von Anomalien in industriellen Wertschöpfungsnetzwerken wurde ein umfangreiches Framework entwickelt. Der Quellcode ist in Python verfasst und bietet anderen Entwicklern weitreichende Anpassungsmöglichkeiten.

Mittels klassischen und modernen Algorithmen maschinellen Lernens können damit relevante Auffälligkeiten im industriellen Netzwerk festgestellt und weiter an den Leitstand gegeben werden.

Generierung bössartiger Netzwerkverkehrsdaten

Für gute Resultate bedingt maschinelles Lernen im Allgemeinen wohlgeformte und hinreichend große Datensätze. Das überwachte Lernen, als eine Form dessen, bedarf darüber hinaus einer eindeutigen Zuordnung der aufgezeichneten Netzwerkpakete zu einem jeweiligen Angriff.

Auf Grund dieses Kennzeichnungsprozesses (engl. labeling) ist die Erstellung solcher Datensätze keineswegs trivial, noch existieren öffentliche Ressourcen mit klassifizierten Daten realer Industrienetze.

Innerhalb einer realen industriellen Umgebung wurden manuell bössartige Netzwerkverkehrsdaten (engl. traffic) in Form von Netzwerksträngen (engl. traces) zwischen Programmable Logic Controllers (PLCs) von Siemens der Serie S7-300 und einem damit verbundenen Kontrollserver generiert.

Die Traces wurden dabei sowohl binär in ‘Normal’ und ‘Angriff’, als auch in fünf verschiedene Angriffe (Authentication Bypass, CPU Stop & Start, Reconnaissance, Denial of Service, Brute Force) multi-klassifiziert.

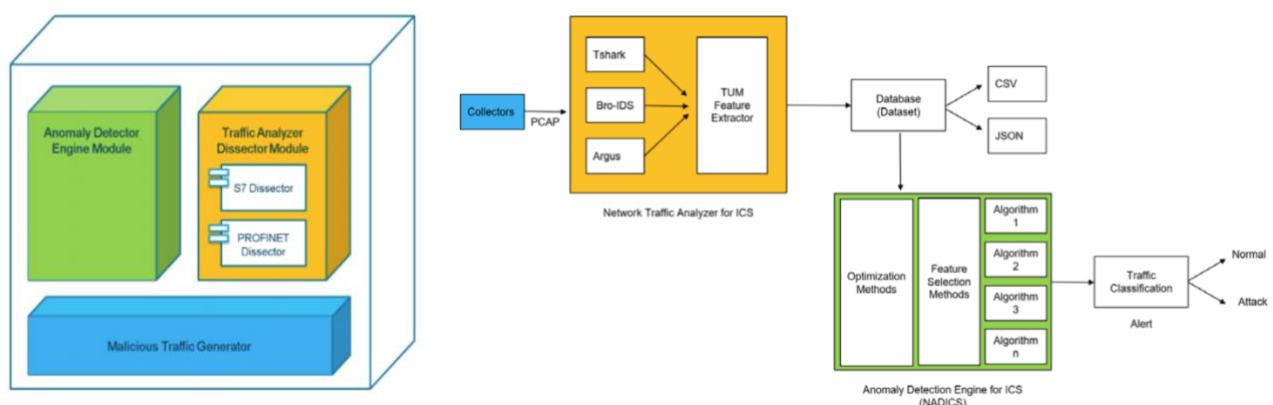


Abbildung 4: Extraktion protokollcharakteristischer Merkmale

Extraktion charakteristischer Merkmale

Der generierte Traffic wird zur weiteren Eingabe für das maschinelle Lernen als Datensatz aufgearbeitet. Zu diesem Zweck werden in einem Modul (Abbildung 4) die protokollcharakteristischen

Merkmale (engl. features) unter der Verwendung öffentlich zugänglicher Software wie Argus, Bro-IDS und T-Shark, sowie eigens entwickelter Methoden, extrahiert. Demnach entspricht ein Datensatz einer Vielzahl an Verbindungen.

Insbesondere ist das Modul in der Lage S7 Connections der aufgezeichneten Traces korrekt zu analysieren und wahlweise als .csv oder .json formatiert auszugeben.

Anomalieerkennung mittels Methoden maschinellen Lernens

Es stehen zur Anomalieerkennung neben der Implementierung von 13 klassischen Modellen sowohl ein Deep Neural Network, sowie ein Convolutional Neural Network zur Verfügung. Insbesondere geht mit der hohen Dimensionalität der Datensätze ein hoher Rechenaufwand einher, sodass die modernen Algorithmen den Einsatz eines leistungsstarken GPU-Systems erfordern.

Das Modul zur Anomalieerkennung stellt darüber hinaus weitere Funktionen bereit, indem Überanpassungen (engl. overfitting, resp. underfitting) an das Modell mittels 15 verschiedenen Algorithmen korrigiert werden können. Extremwerte lassen sich in Form von Neuartigkeiten (engl. novelties) oder statistischer Ausreißer (engl. outliers) identifizieren und als Versuchsfehler relativ zum Datensatz anzeigen. Weiter lassen sich ein möglicher Bias bzw. eine mögliche Varianz mittels zwei implementierter Meta-Algorithmen reduzieren.

Die wichtigsten Features lassen sich außerdem grafisch ausgegeben und im Lernprozess zu Gunsten einer Dimensionsreduktion bzw. einer möglichen Performance-Steigerung selektieren. Zudem kann die Falsch-Positiv-Rate durch diesen Prozess ebenfalls reduziert werden.

Sammlung von Daten

Im Rahmen des Projekts wurde an der Sammlung von Daten und der Erkennung von Anomalien gearbeitet. Der erste Schritt zur erfolgreichen Erkennung von Angriffen ist die Auswahl geeigneter Datenquellen. Dazu wurde ein Aggregationsmodell entwickelt, das Datenquellen hinsichtlich ihrer Art trennt, in Quelle, Ziel und Weg eines Ereignisses. Weiterhin ist die Aggregation auf unterschiedlichen Abstraktionsebenen möglich, um sowohl eine genaue Betrachtung auf Paketebene, als auch eine zusammengefasste Betrachtung einer großen Datenmenge, etwa auf Flow-Ebene zu ermöglichen. Das exemplarische Modell ist in Abbildung 5 abgebildet. Level 1 beschreibt hierbei die Packet-beziehungswese Logeintragsebene. Level 2 ist eine zu Flows oder beispielsweise Logtraces aggregierte Betrachtungsebene, während Level 3 das gesamte Netzwerk betrachtet.

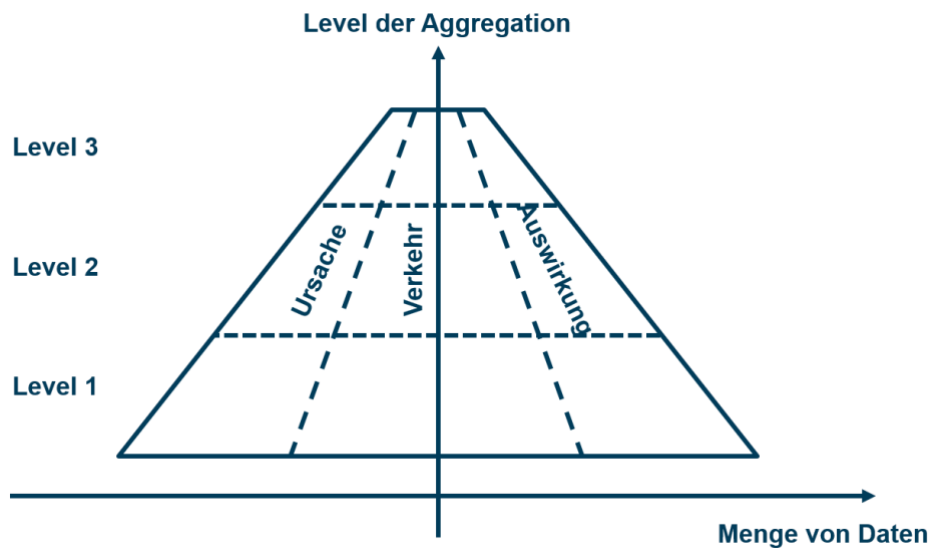


Abbildung 5: Aggregationspyramide

Dieses Aggregationsmodell liegt auch der implementierten Lösung zum Datensammeln zugrunde. Dazu wird ein verteilter Netzwerksniffer verwendet, der durch Portmirroring passiv den Netzwerkverkehr an Switches mitliest. Dadurch wird auch der Verkehr innerhalb eines Subnetzes rückwirkungsfrei erfasst. Der Sniffer ist exemplarisch in Abbildung 6 dargestellt. Mehrere Instanzen des Sniffers werden hierbei kombiniert, um Daten aus allen Subnetzen abzugreifen, lokal auf Level 1 vorzuverarbeiten und in aggregierter Form auf Level 2 an übergeordnete Instanzen zu senden. Ein Level 3 Abbild des Gesamtnetzwerkes ist durch die Kombination aller übergeordneten Instanzen möglich. Die Bewertung und Untersuchung der gesammelten Daten wird in den folgenden Abschnitten vorgestellt.

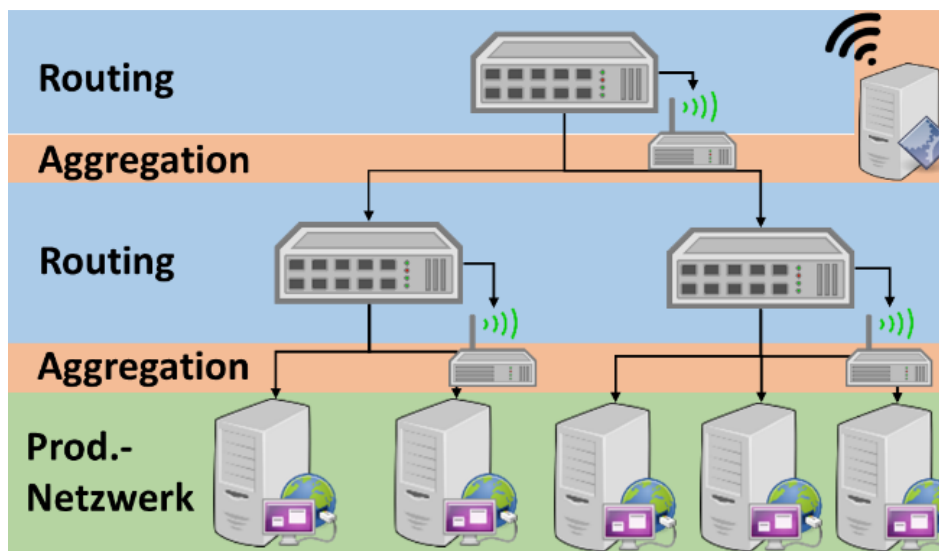


Abbildung 6: Verteilter Netzwerksniffer

Generierung von Daten

Der im vorigen Abschnitt vorgestellte verteilte Netzwerksniffer wurde am Testnetzwerk evaluiert und durch das erhaltene Feedback optimiert. Insbesondere zielt er darauf ab, Level 1 und 2 Informationen des Netzwerkverkehrs zu erzeugen. Dies wird dadurch erreicht, dass lokal .pcap-Dateien mit allen

Paketen erzeugt und verarbeitet werden, während an die übergeordnete Instanz Flow-Informationen gesendet werden. Im folgenden Abschnitt wird erläutert, wie diese Daten auf Anomalien untersucht werden.

Bewertung von Daten

Im Rahmen von IUNO stand die Untersuchung der Erkennung von Angriffen im Fokus. Hierzu wurden vier verschiedene Verfahren auf Paketebene angewendet, um Anomalien zu erkennen: *Random Forests*, *Support Vector Machines (SVMs)*, *k-nächster Nachbar-Clustering* und *k-means Clustering*. *SVM* erzielten hier sehr gute Erfolge bei der Analyse der drei untersuchten Datensätze, *DS1*, *DS2* und *DS3*, wie in Abbildung 7 gezeigt. Auch *Random Forests* wiesen sehr gute Ergebnisse auf, dargestellt in Abbildung 8. Die Clustering-Verfahren erwiesen sich als weniger brauchbar, insbesondere das *k-nächster Nachbar*-Verfahren lieferte lückenhafte Ergebnisse, wie in Abbildung 9 dargestellt, doch auch *k-means Clustering* blieb im Ergebnis hinter den ersten beiden Verfahren zurück, gezeigt in Abbildung 10.

Dataset	Accuracy	F1-score
DS1	1,0	1,0
DS2	1,0	1,0
DS3	0,999 936	0,999 968

Abbildung 7: SVM

Dataset	Accuracy	F1-score
DS1	1,0	1,0
DS2	0,999 701	0,999 851
DS3	0,999 973	0,999 986

Abbildung 8: Random Forest

Dataset	Accuracy	F1-score
DS1	0,981 018	0,990 383
DS2	0,556 242	0,714 853
DS3	0,633 624	0,775 728

Abbildung 9: k-nächster Nachbar

Dataset	Accuracy	F1-score
DS1	0,997 097	0,998 527
DS2	0,999 118	0,999 559
DS3	0,999 412	0,999 706

Abbildung 10: k-means Clustering

Anomalieerkennung auf Basis von LDA

In IUNO wurden Methoden zur Detektion von Anomalien erforscht und im Demonstrator integriert. Zudem wurde ein System zur Verteilung von Meldungen über erkannte Anomalien entwickelt und die dafür benötigte Infrastruktur aufgebaut, sowie unterstützend an der Integration des visuellen Leitstandes mitgewirkt.

Das entwickelte Anomalieerkennungssystem stützt sich auf Methoden aus dem Bereich des maschinellen Lernens und wurde prototypisch im Demonstrator integriert und auf der Hannover Messe 2018 präsentiert. Die zugrundeliegende Idee basiert auf dem Ansatz einen Angriff bereits durch Beobachtung des Netzwerkverkehrs erkennen zu können. Der Fokus bei der Entwicklung und Umsetzung des Anomalieerkennungssystems lag vor allem auf der Erzeugung einer Infrastruktur, welche auch im realen Umfeld genutzt werden kann. Zudem wurde für die Entwicklung ausschließlich mit Echtdateien gearbeitet, welche direkt mithilfe des Demonstrators aus der IUNO Umgebung erzeugt wurden.

Das entwickelte Analyse-Framework kann dabei in 3 Schritte untergliedert werden: die Datenerfassung, das Erzeugen eines Modells und die Analyse.

Bereits die Erfassung des gesamten Netzwerkverkehrs stellt ein System vor komplexe Herausforderungen. Zum einen muss die Erfassung des Datenverkehrs über mehrere Netzwerkknoten hinweg verteilt möglich sein. Zum anderen müssen große Datenmengen erfasst und verarbeitet werden können. Um große Datenmengen möglichst performant persistieren und anschließend weiterverarbeiten zu können, werden die Netzwerkmitschnitte in einem verteilten Dateisystem abgelegt. Dadurch ist es möglich kosteneffizient die Speicherkapazität zu erweitern, sowie dezentral auf die Daten zuzugreifen. Zeitgleich ist der Einlese-Prozess des Netzwerkverkehrs in das dezentrale Dateisystem mithilfe eine Produzenten-Konsumenten Paradigmas umgesetzt, sodass sowohl das Einlesen von unterschiedlichen Netzwerkknoten möglich ist, als auch der Persistierungsprozess auf unterschiedliche Knoten verteilt werden kann und somit dynamisch an Lastspitzen anpassbar ist.

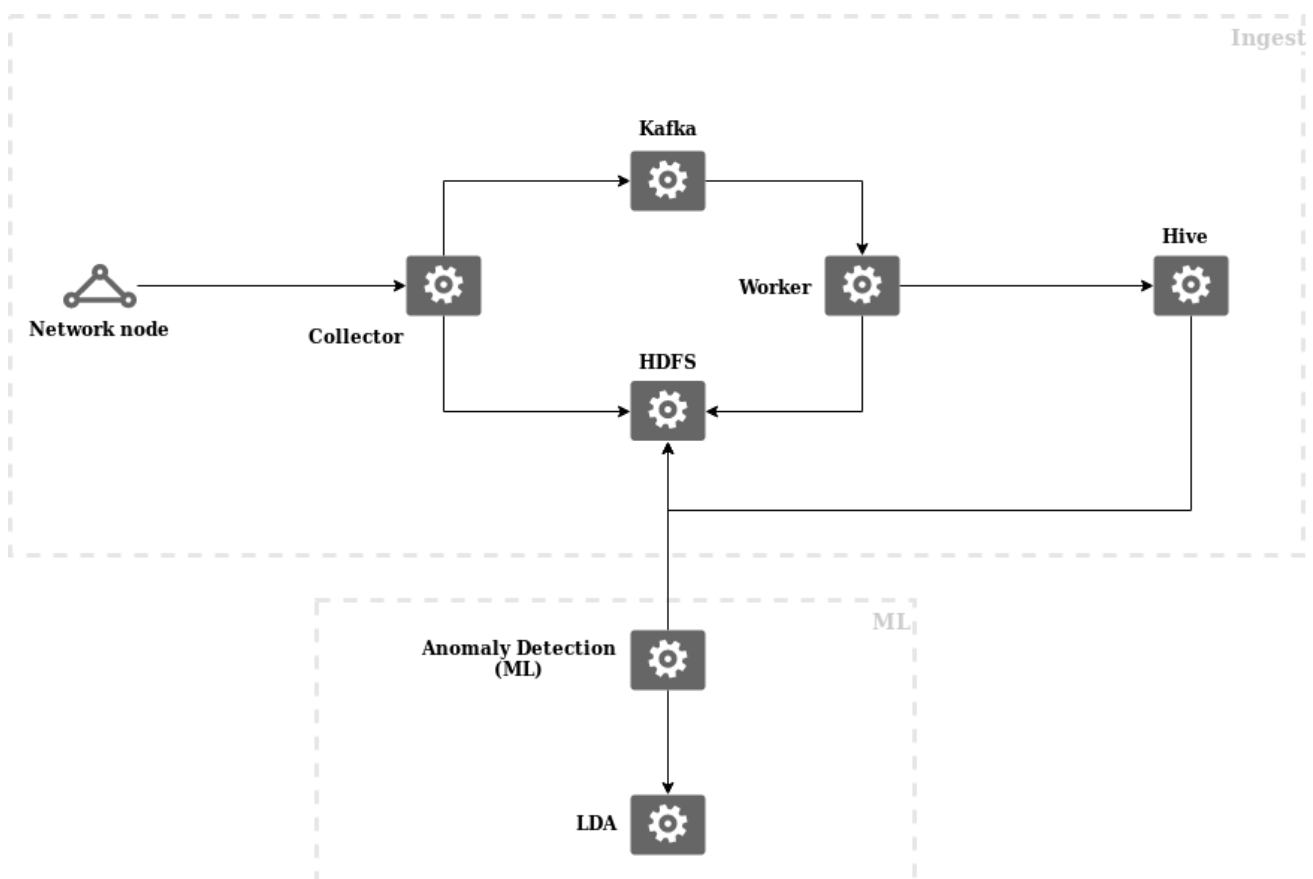


Abbildung 11: Anomalieerkennung

Im nächsten Schritt müssen die erfassten Daten vorgefiltert werden um anschließend ein Modell zu erzeugen, welches den Zustand des Netzwerkes abbildet. Hierbei wurde auf LDA, Latent Dirichlet Allocation, aufgebaut. LDA ist ein Clusteringalgorithmus, welcher ursprünglich dazu genutzt wurde, Textdokumente zu kategorisieren. Dabei wird die Häufung von Wörtern bei Themen genutzt um ein Zusammenhang zwischen Themen und Wörtern herzustellen. Infolgedessen kann das Thema oder die Themen eines Dokumentes aus den darin enthaltenen Wörtern geschlussfolgert werden. Dieser Zusammenhang lässt sich auch auf das Kommunikationsverhalten von Netzwerkteilnehmern

übertragen. Der Datenaustausch zwischen zwei Netzwerkteilnehmer sind dabei das Äquivalent zu einem Dokument und die ausgetauschten Pakete bilden das Pendant zu den Wörtern.

Um die persistieren Netzwerkdaten effizient mittels LDA weiterverarbeiten zu können wurde bei der Umsetzung auf ein leistungsfähiges Datenbank-Technologie gesetzt, welche es erlaubt große Datenmengen verteilt bearbeiten zu können. Mit Apache Spark können Datenbankabfragen auch über mehrere Datenbankknoten hinweg verteilt ausgeführt und vorverarbeitet werden. Dadurch müssen komplexe Berechnungen nicht zentral an einer Stelle verarbeitet werden und das Gesamtsystem kann mittels Skalierung auf Last reagieren.

Im letzten Schritt werden die vom Modell als unwahrscheinlich deklarierte Netzwerkcluster extrahiert. Hierbei werden die Wahrscheinlichkeiten für Kommunikationen zwischen unterschiedlichen System herangezogen und miteinander verglichen. Weicht ein Kommunikationsverhalten weit von der Norm ab, wird dies durch eine geringe Wahrscheinlichkeit mathematisch belegbar dargestellt. Bei Detektierung einer solchen Anomalie wird eine Warnmeldung an den Sicherheitsleitstand versandt und damit einem Mitarbeiter die Möglichkeit zu weiteren Nachforschungen und dem Abgleich mit anderen Sicherheitssystem gegeben.

Durch die ausschließliche Nutzung von Echtzeiten konnte zum Einen aufgezeigt werden, dass das eingesetzte Verfahren zu einer erheblichen Datenreduktion geeignet ist und somit wirksam normale von anomalen Netzwerkclustern unterscheiden kann. Hierbei zeigen die aufkommenden false positives – sprich erkannte Anomalien, welche streng genommen als normales Verhalten zu klassifizieren wären – den anhaltenden Bedarf für weitere Forschungen. Der Aufbau der zugrundeliegende Infrastruktur wurde mittels Docker stark vereinfacht und bildet somit eine sehr dynamische Grundlage für unterschiedliche Anwendungsfälle. Trotzdem bildet die damit einhergehende Komplexität eine gewisse Einstiegshürde, welche noch optimiert werden kann um die zukünftig noch weiter anwachsenden Datenmengen weiterhin zeitnah verarbeiten zu können.

Integritätsüberwachung von Feldbusnachrichten

Die Sicherstellung der Integrität komplexer Produktionsanlagen, wie sie für die Industrie 4.0 typisch sind, ist essentiell für ihre Produktivität und die Qualität der Produkte. Unter Integrität einer Produktionsanlage ist hierbei zu verstehen, dass sich eine Anlage so verhält wie sie geplant und konfiguriert wurde. Wird die Integrität von Produktionsanlagen verletzt, kann dies zu Qualitätsproblemen der Produkte und zu einer eingeschränkten Verfügbarkeit der Produktion führen.

Neben der Integrität der beteiligten industriellen Komponenten trägt die Integrität der Kommunikation über Feldbusprotokolle zwischen diesen Komponenten wesentlich zum Systemverhalten bei. Bei der Spezifikation von Ethernet-basierten Feldbusprotokollen standen die Funktionalität und die funktionale Sicherheit (Safety) im Vordergrund. Kryptographische Sicherheitsmechanismen zur Authentifikation und Integritätssicherung der Nachrichten (Security) waren auch aus Gründen von Echtzeitanforderungen der Protokolle in der Vergangenheit nicht im Fokus. In aktuellen Industrie 4.0 Szenarien kann die Kommunikation auf Feld- und Steuerungsebene durch eine dem Risikobedarf gerechte Zonierung und der Umsetzung von Zellenschutzkonzepten geschützt werden. Der Zugriff auf Komponenten einer Zone von Entitäten außerhalb der Zone ist stark reglementiert.

In zukünftigen Industrie 4.0-Szenarien wird die Flexibilität der Kommunikationsbeziehungen zunehmen. Statische Ansätze zum Schutz der Komponenten auf Feldebene können nicht mehr das gleiche Schutzniveau bieten wie dies heute möglich ist. Zudem besteht aus Sicht eines Betreibers der Bedarf, Manipulationen der Kommunikation frühzeitig zu detektieren.

Um diesen Anforderungen gerecht zu werden wurde in IUNO ein Werkzeug prototypisch entwickelt und erprobt, welches eine passive Überwachung der Integrität von Ethernet-basierten Feldbusnachrichten ermöglicht. Die Integrität der Nachrichten wird hierbei kontinuierlich durch Integrity-Sensoren ermittelt. Diese Sensoren nehmen an Hand von Filterkriterien den Datenverkehr zwischen industriellen Komponenten auf und berechnen kryptographische Integritätsreferenzwerte. Das Monitoring erfolgt rückwirkungsfrei für die Feldbusprotokolle, um die Automatisierungsprozesse nicht zu beeinflussen. Die Integritätsreferenzwerte werden in einer übergeordneten Instanz (Integrity Authority) korreliert und geprüft (siehe Abbildung). Damit lässt sich zeitnah feststellen, ob Inhalte von Feldbusnachrichten auf ihrem Weg durch das Netzwerk verändert wurden, oder ob Nachrichten unautorisiert in das Automatisierungsnetzwerk eingespielt wurden.

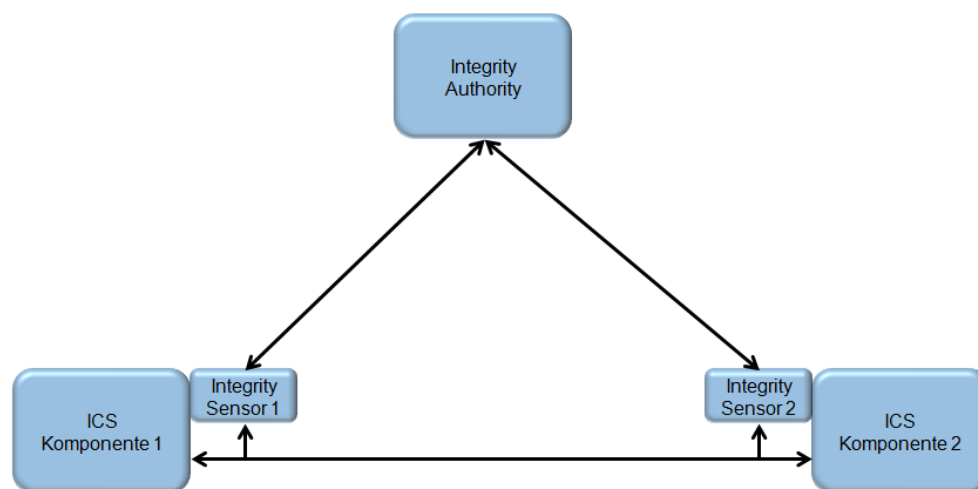


Abbildung 12: Architektur Integritätsüberwachung Feldbusnachrichten

Im Demonstrator „Visueller Security-Leitstand“ wurden die Integrity-Sensoren auf Basis einer kostengünstigen Raspberry Pi 3 Hardware integriert. Die Funktionalität der Integrity-Authority wurde auf einem Ubuntu-Server realisiert. Zusätzlich wurden TAP Devices in das Netzwerk integriert, um den Datenverkehr zwischen den ICS Komponenten rückwirkungsfrei auszuleiten. Die TAP Devices sowie die Sensoren werden hierbei möglichst nahe an der zu überwachenden ICS Komponente eingebracht. Für die Feldbusnachrichten wird ein Integritätsreferenzwert berechnet und weitergeleitet, welcher meist deutlich kürzer als die ursprüngliche Profinet Nachrichten ist.

Der Datenverkehr zwischen Integrity-Sensoren und Integrity Authority wird durch einen beidseitig authentifizierten und verschlüsselten TLS-Kanal realisiert, um die Integrität und Vertraulichkeit zu gewährleisten. Dafür wurden individuelle X.509 Geräte-Zertifikate auf allen beteiligten Komponenten durch ein IAM-System provisioniert. Für die Speicherung des privaten Schlüssels der Integrity-Sensoren, sowie die Durchführung von kryptographische Operation mit diesem in einer gesicherten Umgebung, wurden TPMs (Trusted Platform Module 2.0) auf den Raspberry Pis integriert.

Die Umsetzung ist nicht auf zwei Sensoren beschränkt, sondern es kann je nach Risikobedarf pro zu überwachender ICS Komponente ein Integrity-Sensor eingesetzt werden. In einer Ausbaustufe könnte ein Sensor den Datenverkehr von mehreren ICS Komponenten gleichzeitig überwachen. Der im Demonstrator erprobte Ansatz erlaubt eine skalierbare Überwachung der Integrität von Feldbusnachrichten in Brownfield Installationen. Es lassen sich veränderte Nachrichten (Man in the Middle Angriff) oder zusätzlich eingespielte Datenpakete (z.B. Replay Angriff) auf der Profinet-

Strecke zwischen den Integrity-Sensoren zeitnah erkennen. Alarme werden über das syslog-Protokoll zum IUNO Aggregationssystem und damit zum visuellen Security-Leitstand gemeldet.

Identity und Access Management

Das Identity und Access Management (IAM) System ermöglicht, Kommunikationspartnern, Servern, Clients, usw. einander sicher zu identifizieren und zu authentisieren, sowie den autorisierten Zugriff auf benötigten Ressourcen durchzusetzen. Ein typisches IAM-System umfasst mehrere Komponenten, z. B. Identitätsmanagement, Authentifizierungs- und Autorisierungsverwaltung, Federation und Delegation Management und Compliance Management. Die PKI Komponente des IAM-Systems stellt eine sichere digitale Identität bereit, die von einer Entität (z. B. einem Benutzer, einem Gerät oder einer industriellen Komponente) verwendet wird, um mit anderen IT-Systemen innerhalb der Organisation sicher zu kommunizieren. Die Public-Key-Infrastruktur (PKI) verwendet ein eindeutiges öffentlich-privates Schlüsselpaar, wobei der öffentliche Schlüssel von der vertrauenswürdigen Entität, d. h. der Zertifizierungsstelle (CA), zertifiziert und als X.509-Zertifikat ausgegeben wird.

Legacy industrielle Systeme und Netzwerke unterscheiden sich von herkömmlichen IT-Systemen und Netzwerken, weil man davon ausging, dass sie für Angreifer unerschließbar wären. Eine Annahme die mit zunehmender und flexiblerer Kommunikation und Integration nicht mehr gültig ist. Existierende Lösungen verwenden oft ad-hoc Methoden um den Endteilnehmern betriebliche Zertifikate bereitzustellen. Diese Prozeduren sind in der Regel manuell, nicht standardisiert, proprietär, unflexibel, nicht skalierbar und unsicher. Wenn die privaten Schlüssel kompromittiert sind, ist es leicht, sie zu missbrauchen und sich als diese Identitäten auszugeben. Um dies zu verhindern und um Interoperabilität zu garantieren, muss in der Industrie 4.0 die sichere Bereitstellung von Zertifikaten über standardisierte Zertifikatskommissionierungsmethoden mit überprüften und anerkannten Sicherheitsmaßnahmen gewährleistet sein.

In dem IUNO Projekt wurde ein relativ minimalistisches IAM-Prototypsystem entwickelt, das in der Lage ist, operationelle X.509 Zertifikate an IUNO Security-Komponenten wie Integrity-Authority, Integrity-Sensoren und IAM-Server zu liefern. Dieser Ansatz kann direkt auf industrielle Komponenten wie Roboterarme oder PLCs übertragen werden. Die Lösung basiert auf dem standardisierten Certificate Management Protocol (CMP) und verwendet die Open-Source OpenSSL-CMP-Bibliothek. Aus der Sicht der Administratoren ist lediglich ein minimaler Verwaltungsaufwand für die Bereitstellung von Zertifikaten akzeptabel. Darüber hinaus wurde ein leichtgewichtiger Client-Server-Dienst realisiert, um Identitätsmissbrauch, Fehlererkennung und die Verwendung ungültiger Zertifikate in der Fabrikumgebung zu erkennen.

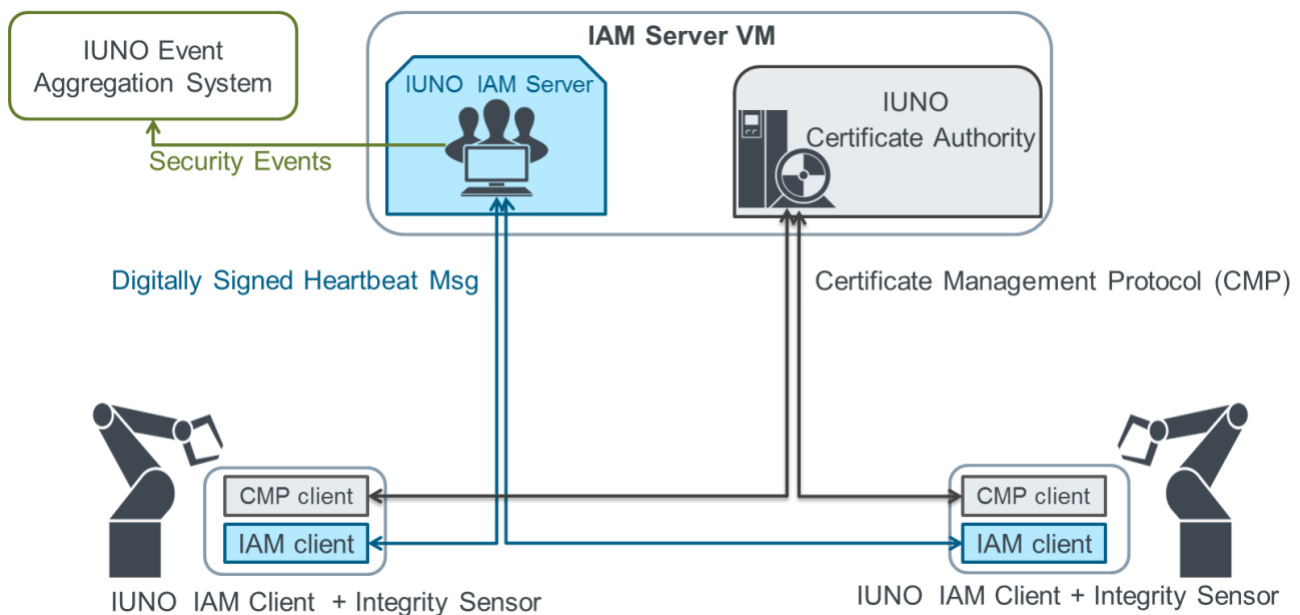


Abbildung 13: Architektur einer Konfiguration des IUNO IAM-Demonstrators

Die Abbildung zeigt die Architektur einer Konfiguration des IUNO IAM-Demonstrators, in dem die IUNO-Clients CMP für die Zertifikatsverteilung verwenden. Die virtuelle IUNO IAM-Maschine (oben im Bild) besteht aus dem IAM-Server und der IUNO Certificate Authority (CA). Der IUNO IAM-Serverdienst registriert und überwacht die industriellen Geräte und führt den UDP-basierten Heartbeat-Protokollserver-Dienst aus, um Identitätsmissbrauch zu erkennen. Dafür stellt der IAM-Clientdienst eine Verbindung mit dem IAM-Serverdienst her und sendet regelmäßig digital signierte Heartbeat-Nachrichten an den IAM-Server. Das entwickelte Protokoll verwendet einen Challenge-Response-Mechanismus, um den IAM-Client zu authentifizieren, wenn die Verbindung zum IAM-Server unterbrochen wurde. Dieser Challenge-Response-Mechanismus verhindert Replay-Angriffe von Rouge-Client-Geräten.

In industriellen Umgebungen wird oft die Angriffsfläche eines Insiders, der Zugang zu physischen Geräten hat, übersehen. Sie haben oft die Möglichkeit kryptografisches Schlüsselmaterial zu stehlen, Angreifer-HW zu installieren oder Man-in-the-Middle-Angriffe ausführen. Mögliche Angriffe gegen den hier entwickelten UDP-basierten Heartbeat-Dienst wurden untersucht und geeignete Erkennungsmaßnahmen wurden entwickelt. Alle vom IUNO-IAM-Server erkannten Sicherheitsereignisse werden über Syslog-Nachrichten als Frühwarnsystem an das IUNO-Aggregationssystem weitergeleitet.

Die IUNO PKI-Zertifizierungsstelle basiert auf dem Open-Source Enterprise Java Beans Certificate Authority (EJBCA) Softwarepaket. Bei einer gültigen Zertifikatanforderung mit eindeutigem Distinguished Name (DN), stellt die Zertifizierungsstelle ECC-basierte Zertifikate aus. Das in RFC 4210 standardisierte Certificate Management Protocol (CMP) wird für alle Zertifikatsmanagementvorgänge wie Zertifikatsausstellung, -rückruf usw. verwendet. IAM-Server und -Client-Service werden mit Python 2.7 unter Verwendung mehrerer Bibliotheken einschließlich fastercc und JSON entwickelt. Die IAM-Server-VM basiert auf dem Ubuntu-Betriebssystem, und der IAM-Client verwendet das Raspbian-Betriebssystem, das auf einem Raspberry-Pi-3 ausgeführt wird. Das Heartbeat-Protokoll wurde so konzipiert, dass es effizient und flexibel ist. Es wird Integrität und nicht Vertraulichkeit der Heartbeat-Nachrichten gefordert und aus Effizienzgründen (sowohl hinsichtlich der Bandbreite als auch der CPU) können sie nicht verschlüsselt oder über DTLS gesendet

werden. Daher werden sie über das leichtgewichtige UDP (User Datagram Protocol) verschickt. Das stellt sicher, dass unser Protokoll möglichst wenige Ressourcen verbraucht und somit andere bestehende industrielle Kommunikationsnetzwerke nicht beeinträchtigt, aber doch in der Lage ist, eindeutige und sichere Identitäten bereitzustellen und Angriffe wie Replay-Attacken, Identitätsmissbrauch oder ungültige Zertifikate zu erkennen.

SPS-Fehlererkennung

Ziel der hier beschriebenen Methoden ist die Überwachung einer Maschinensteuerung (Speicherprogrammierbare Steuerung, SPS) anhand ihrer Kommunikation mit den daran verbundenen Komponenten.

Die dafür entwickelte Fehlererkennungslösung ermittelt den fehlerfreien Sollzustand der überwachten SPS aus einer Simulation des Betriebsprogrammes sowie den Sensordaten aus dem Feldbussystem der Anlage. Anschließend vergleicht sie die Ausgaben der Simulation mit den Werten, die am Feldbus anliegen. Sobald eine Abweichung festgestellt wird, die länger als die von der SPS garantierte Reaktionszeit besteht, wird eine Warnung ausgegeben, die den ungültigen Zustand exakt beschreibt. Diese Methode kann sowohl (unautorisierte) Veränderungen an den SPS-Programmen als auch Defekte im Gerät selbst detektieren, die zu einer Veränderung des Maschinenverhaltens führen. Außerdem hat sich die entwickelte Software als nützlich beim Nachvollziehen von Programmierfehlern erwiesen, da man den internen Zustand einer Anlage in einer unabhängigen Instanz analysieren kann, ohne sie selbst anhalten zu müssen.

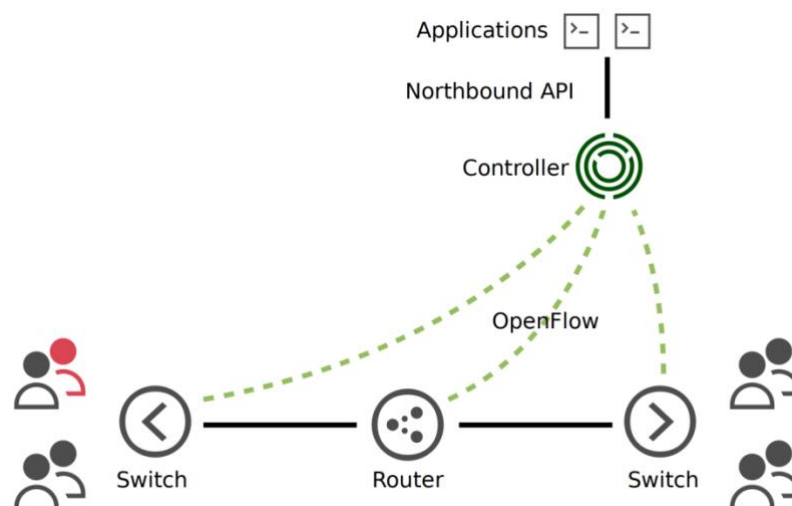


Abbildung 14: Architektur eines SDN-Netzes

Moderne Industriesysteme werden deutlich stärker vernetzt sein als heute. Eine Schlüsseltechnologie für die flexible Vernetzung komplexer Strukturen ist dabei Software Defined Networking (SDN).

Zur Evaluation der Einsatzfähigkeit wurde eine Anlage über ein 4-Port-SDN-Switch, das via OpenFlow-Protokoll [OpenFlow] von einem PoX-Controller [PoX] gesteuert wurde, in einen Feldbus integriert. Auf dem Controller lief eine Applikation, die klassisches Switching bereitstellte, sowie eine Eigenentwicklung, die alle Pakete, die Feldbusnachrichten enthielten, an einen separaten Monitorport spiegelte. Die Fehlererkennung ließ sich hierbei in vollem Umfang verwenden. Die Lösung wurde mehrfach ausgestellt, unter anderem auf der Hannover Messe 2017.

Um eine effiziente Interpretation der extrahierten Feldbusdaten sicherzustellen, wurden verschiedene Parserbeschreibungssprachen und Werkzeuge auf ihre Eignung geprüft [D4.2]. Aufgrund der außergewöhnlichen Performance und Integrationsfähigkeit in SDN-Netzen wurde P4 [P4] zur Erzeugung der benötigten Parser eingesetzt. Die anschließende Implementierung von Parsern für Profinet, Modbus und darunterliegender Basisprotokolle gestaltete sich damit weitgehend problemlos.

Zusätzlich konnte ein Tool entwickelt werden, das aus den Konfigurationsdateien der genutzten SPS-Entwicklungsumgebung „Step7“ P4-Parserbeschreibungen erstellt. Somit konnte die Interpretation der extrahierten Daten ebenfalls automatisiert mit P4 vorgenommen werden. Die Ausgabedaten der Parser beinhalten also bereits vollständige Variablennamen und können so direkt als Istzustand verwendet sowie in die Simulation geladen werden.

Der Sollzustand der überwachten Maschine ist durch das sich auf der SPS befindliche Betriebsprogramm definiert. Die SPS muss dieses innerhalb eines definierten Zeitfensters ausführen und die Ausgabewerte auf dem Feldbus zu Verfügung stellen.

Eine Simulation dieses Betriebsprogramms liefert der Überwachungssoftware also die Sollwerte als Ausgabe. Diese können anschließend mit den auf dem Feldbus anliegenden Werten verglichen werden.

Da SPS-Entwicklungsumgebungen eigene Programmiersprachen verwenden, müssen dort implementierte Programme zuerst in eine Sprache konvertiert werden, die für das Fehlererkennungssystem kompilierbar ist. Im Falle der verwendeten Siemens-SPS wurde SCL eingesetzt, eine Abwandlung von Structured Text (ST), wie in IEC 61131-3 spezifiziert. Der IEC-Standard selbst bietet eine Grammatikdefinition aus der mit geeigneten Werkzeugen automatisch Parser generiert werden können.

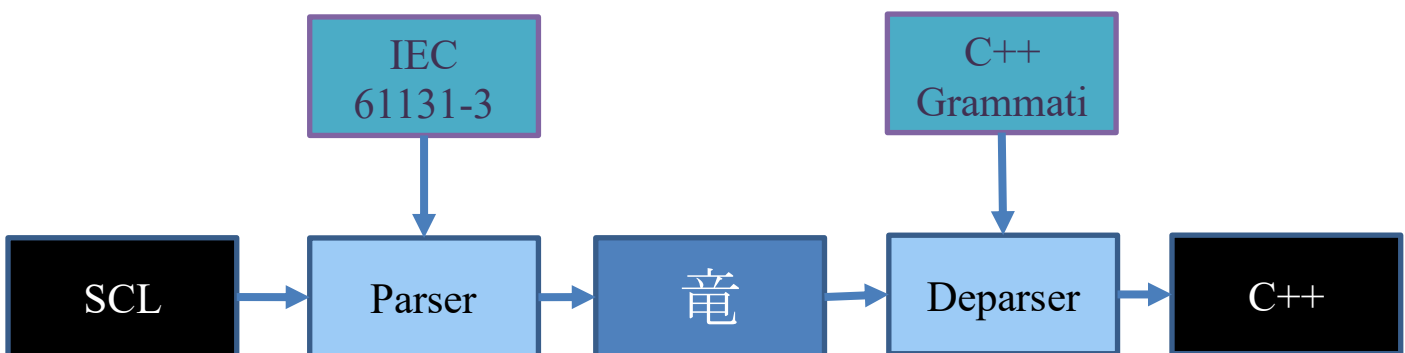


Abbildung 15: Sprachenkonvertierung zur Sollzustandsermittlung

Das im Rahmen der Implementierung genutzte Werkzeug „竜 TatSu“ [TatSu] konnte dabei erfolgreich verwendet werden, um die SCL-Programme in C++ zu konvertieren. Diese konnten anschließend mit dem Compiler GCC [GCC] in ein Binärobjekt übersetzt werden. Das Binärobjekt liefert dabei für jedem Ausführungszyklus einen kompletten Satz an Sollwerten basierend auf den geladenen Eingabewerten.

Die aus der Simulation ermittelten Sollwerte werden nach deren Erzeugung vom Erkennen mit den vom Feldbus extrahierten Aktor-Werten verglichen.

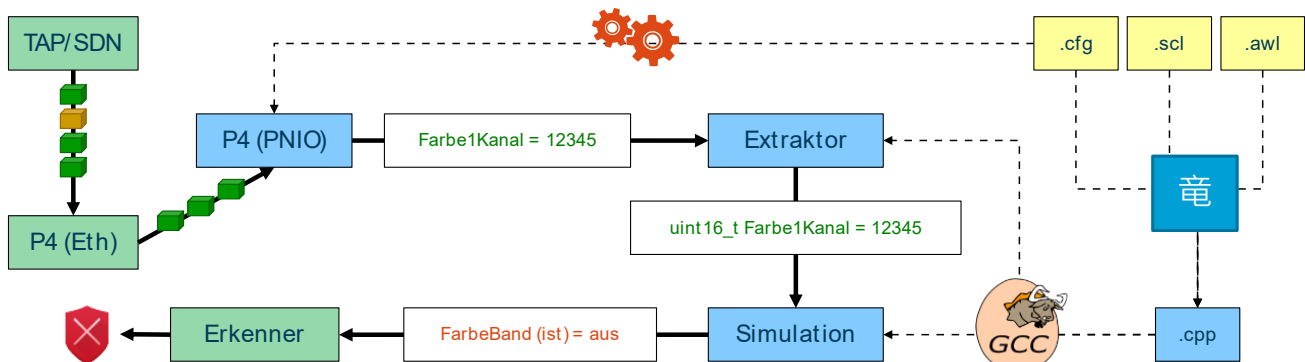


Abbildung 16: Gesamtarchitektur der Fehlererkennungssoftware

Dieser Vergleich gestaltet sich relativ einfach, da die SPS durch ihre strengen Echtzeit-Vorgaben innerhalb eines fest definierten Zeitfensters reagieren muss. Dieses Zeitfenster, dass in allen untersuchten Anlagen im Millisekundenbereich konfiguriert war, findet auch Anwendung im Erkennen. Sobald sich ein Ausgabewert auf dem Feldbus ändert, muss die Simulation innerhalb dieses Zeitfenster ebenfalls diesen Wert liefern. Ändert sich der Wert zuerst in der Simulation, muss er entsprechend innerhalb des Zeitfensters auch auf dem Feldbus anliegen.

Wird diese Regel verletzt, erzeugt der Erkennen eine Leistungs-Meldung, die die Abweichung dokumentiert. Der verantwortliche Bediener kann anschließend die Ursache ermitteln. Dazu ist es möglich, aufgezeichnete Feldbusdaten erneut in eine separate Simulation einzuspielen und diese an bestimmten Stellen zu pausieren, um den Vorfallhergang detaillierter zu analysieren.

Während der Entwicklung der Lösung konnten bereits erfolgreich Fehler in den Demonstratoren aufgedeckt werden: Es wurde eine schwerwiegende Fehlfunktion in der Open Source SPS-Lösung OpenPLC entdeckt, die zur Beschädigung von Komponenten führen könnte. Außerdem konnte ein bekanntes Problem in einer Modellfabrik von Volkswagen durch die Fehlererkennung bestätigt werden. Dabei konnte die Simulation einen bisher als Ursache angenommenen Programmierfehler ausschließen.

Die gezeigte Lösung lässt sich gut für kritische Bereiche der Produktion einsetzen, da sie sehr zuverlässig arbeitet und sich neben der Angriffserkennung auch bei der Fehlersuche einsetzen lässt. Alle Ergebnisse sind mit extrem hoher Wahrscheinlichkeit tatsächliche Fehlfunktionen, Falsch positive Meldungen sind während der gesamten Einsatzzeit nicht aufgetreten. Die gute Detektionssicherheit verlangt im Gegenzug einige Vorbereitung, da für jede Anlage und Softwareversion eine Simulation erzeugt werden muss. Dies lässt sich zwar automatisieren, verlangt aber ein zuverlässiges Management der betroffenen Maschinen, Mitarbeiter und Software.

Die Performance ist ausreichend, um auch ohne Rechenzentrum eine mittelgroße Fabrik zu überwachen. Auf einem handelsüblichen PC können pro Prozessorkern etwa 8 SPS parallel überwacht werden. Die einmalige initiale Erzeugung der Parser, Übersetzen des Programmcodes und anschließendes Kompilieren benötigen nur wenige Sekunden. Ebenso lässt sich das System problemlos skalieren, die Parsingaufgaben können dank der umfangreichen Backends von P4 etwa auf dedizierte Hardware ausgelagert werden.

Aggregationssystem

Das Grundkonzept des visuellen Security-Leitstands sieht vor, dass eine potentiell große Zahl von Systemen Daten generieren und kommunizieren, teils untereinander, teils mit dem Leitstandssystem

selbst. Zu diesem Zweck wurde in IUNO ein generisches Aggregationssystem für den Security-Leitstand und Analysesysteme entwickelt und prototypisch implementiert. Da sich, je nach industriellem Umfeld und Unternehmen, die Systeme zur Analyse des Sicherheitsniveaus (z.B. Anomalieerkennung und/oder IAM) stark unterscheiden können, war eine zentrale Anforderung an das Aggregationssystem, möglichst geringe Anforderungen sowohl an Systemressourcen, aber auch bzgl. Entwicklungsaufwand zu haben. Gleichzeitig sollte das System flexibel erweiterbar und skalierbar sein, da die Anzahl der prozessierten Daten potentiell sehr hoch werden kann und die Daten in hoher Frequenz kommuniziert werden können.

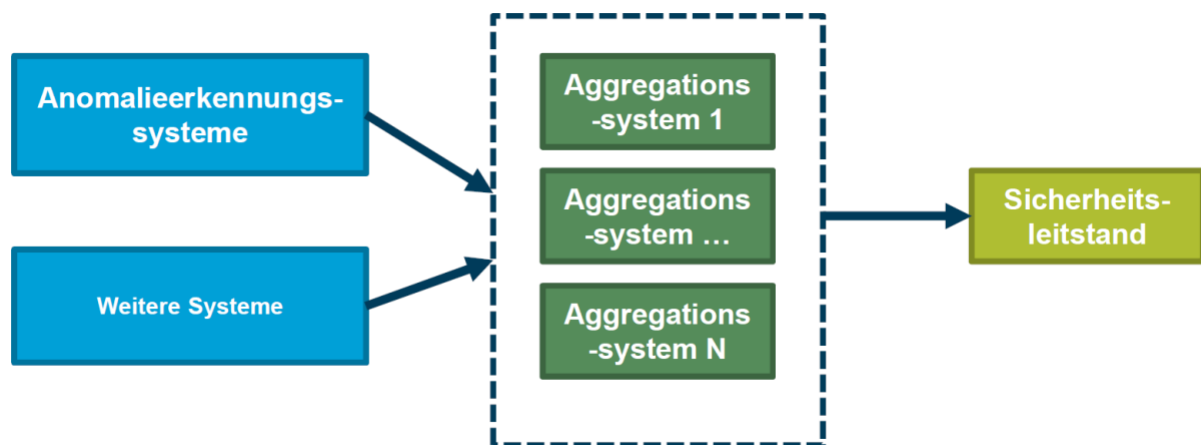


Abbildung 17: Aggregationssystem

Um die Einstiegshürde für die Verwendung des Aggregationssystems und damit letztlich auch des Security-Leitstands zu verringern, wurde beschlossen kein zwingendes Datenformat für die Kommunikation von Events festzulegen. Vielmehr muss es möglich sein, mit geringem Entwicklungsaufwand, schnell Daten per Aggregationssystem zu kommunizieren, welche dann von interessierten Abnehmern der Daten weiter prozessiert werden. Auf diese Weise sollte auch ermöglicht werden Altsysteme über einfache Adaptern und Kommunikationsmodulen am Aggregationssystem und damit auch dem Leitstand teilnehmen zu lassen. Eine weitere potentielle Hürde für die Verwendung des Security-Leitstands sind Lizenzkosten. Es wurde daher beschlossen sämtliche Komponenten des Aggregationssystems auf freier Open-Source-Software basieren zu lassen. Zu guter Letzt sollte der Betrieb des Aggregationssystems keine negativen Auswirkungen auf die Produktivsysteme der Produktion und das Produktionsnetzwerk haben.

Auf Basis dieser Anforderungen wurde eine Infrastruktur zusammengestellt, die aus den zentralen Bausteinen Docker und Apache Kafka basiert. Diese Kombination an Werkzeugen hat ihren Ursprung aus dem Cloud- und Big Data-Umfeld. Apache Kafka ist dabei die wesentliche Kommunikationskomponente. Die Open-Source-Software implementiert ein dezentrales Publish-Subscribe-System und erfüllt damit oben genannte Anforderungen. In der in IUNO verwendeten Konfiguration können bei entsprechender Skalierung können Events im 100k-Bereich pro Sekunde verarbeitet werden. Eine besondere Stärke hierbei ist, dass keine besondere Hardware nötig ist um entsprechenden Datendurchsatz und geringe Latenzen zu erreichen. Sämtliche verwendeten Komponenten des Aggregationssystems kommunizieren über das Netzwerk ausschließlich verschlüsselt per TLS. Die Gegenseitige Authentifikation erfolgt dabei mittels Zertifikaten, die im Demonstrator von der *IUNO Certificate Authority* (siehe Identity und Access Management) stammen.

Der Datenaustausch mit dem Aggregationssystem erfolgt in Form von Eventmeldungen in JSON-Format. JSON ist ein weitverbreitetes Nachrichtenformat, dass unterstützende Werkzeuge und Bibliotheken für viele Systeme und Programmiersprachen bietet. Eine weitere Spezifikation oder Reglementierung des Nachrichtenformats wird in IUNO mit Absicht nicht vorgenommen. Das Grundkonzept hierbei ist, dass Nachrichtenerzeuger (Publisher) nahezu beliebig formatierte Nachrichten im JSON-Format in das Aggregationssystem leiten und Nachrichtenempfangende Systeme (Subscriber) die Daten entsprechend selbst nach ihren Belangen aufarbeiten. Durch die Verwendung von Kafka als Basistechnologie ist es zusätzlich möglich Nachrichten direkt im Aggregationssystem umzuformatieren oder auch zu kombinieren und anzureichern. Hierfür müssen entsprechende Methoden in Form von KSQL-Queries im Aggregationssystem angelegt und aktiviert werden. Neben der Möglichkeit Nachrichten im JSON-Format abzusetzen, existieren viele Bibliotheken zur direkten Anbindung von Log-Systemen an Apache Kafka. So verwendet z.B. das oben beschriebene IUNO IAM-System zum loggen seiner Eventdaten Syslog. Für den Security-Leitstand relevante Events werden mittels einer Bibliothek direkt aus Syslog ins Aggregationssystem abgesetzt.

Das Aggregationssystem in IUNO ist prinzipiell als dezentrales System ausgelegt, kann aber auch, zu Ungunsten der Skalierbarkeit und Leistungsfähigkeit, zentral konfiguriert werden. Um das Deployment der Komponenten des Aggregationssystems maximal zu vereinfachen, wurde auf Docker und entsprechend Dockercontainer gesetzt. Zentraler Bestandteil der Architektur des Aggregationssystems ist ein Cluster aus sogenannten Brokern, also Systemen die für die Annahmen und entsprechende Weiterleitung von Daten zuständig ist. In IUNO werden eben diese Brokerkomponenten in Form von Dockercontainern angeboten. Diese hat zum einen den Vorteil, dass alle Softwareabhängigkeiten und eine Grundkonfiguration bereits im Container gekapselt sind. Zum anderen ist es somit auch möglich schnell und bedarfsorientiert das Cluster an Brokern nach oben oder auch nach unten zu skalieren. So können Unternehmen ressourceneffizient auf Nachrichtenspitzenlasten oder auch Zeiträume mit weniger Nachrichtenlast reagieren.

Visualisierung im Security-Leitstand

Die Visualisierungskomponente hat schließlich das Ziel, relevante Daten über den aktuellen Stand der Informationssicherheit ganzheitlich und übersichtlich abzubilden. So werden Abweichungen in der Produktion sofort sichtbar und sind korrigierbar. Die graphische Web-Oberfläche ist umfangreich in der Funktionsauswahl, um individuellen Anforderungen gerecht zu werden und gleichzeitig flexibel in der Gestaltung. So wurde insbesondere großen Wert auf die Erstellung eines Responsive-Designs gelegt, welches den Designcharakter und die damit verknüpften Funktionen auf verschiedensten Endgeräten wie Smartphones, Tablets oder Leitstandsmonitoren gewährleistet.

Die in Abbildung 18 dargestellte Oberfläche des Security-Leitstands zeigt den Normalzustand an. Ein Experte des Unternehmens hat die Möglichkeit, Informationen über seinen Verantwortungsbereich einzusehen. Sicherheitsvorfälle erscheinen oben links in der Tabelle, unterstützt durch die Grafiken der anderen Bereiche.



Abbildung 18: Oberfläche des Security-Leitstands

Im Sinne einer einfachen Bedienung ist die Oberfläche neben der klassischen Bedienung auch für eine Touch-Bedienung optimiert. Sogenannte Dashboards lassen sich für unterschiedliche Bereiche oder Nutzer individuell anlegen und modular aufbauen. Hierzu kann eine Konfigurationsansicht aktiviert werden (siehe Abbildung 18), in der per Drag&Drop unterschiedliche Diagrammtypen (zum Beispiel Heatmaps, Säulen-, Kreisdiagramme) in drei vordefinierte Bereiche hinzugefügt werden können. Es stehen dabei bereits vorkonfigurierte Elemente aus den drei Bereichen Sicherheit, Netzwerk und Geräte zur Verfügung. Nach dem Beenden der Konfigurationsansicht sind die Elemente in der Größe veränderbar und mit anderen Elementen tauschbar, um beliebige Dashboard-Ansichten zu generieren. Das Entfernen ist ebenso einfach, indem die Elemente in einen vordefinierten Bereich gezogen werden, ähnlich wie es von Android-Oberflächen bekannt ist.

Dezentrale Datenverteilung

Die IT-Landschaft im industriellen Bereich unterliegt einem stetigen Wandel. Bedingt durch die Herausforderungen der Industrie 4.0 wird insbesondere der Durchlässigkeit und Erreichbarkeit von Ressourcen ein hoher Stellenwert beigemessen. Viele eingebettete Systeme im Produktionsumfeld verfügen über optimierte Rechenkapazitäten, sowie über Kommunikationsmöglichkeiten verschiedener Art. So stehen neben den etablierten drahtgebundenen Bussystemen auch Funknetzwerke und sogar komplette Internetanbindungen bereit. Von Seiten der Betreiber bietet die zunehmende Vernetzung Vorteile, die sich im Bedienkomfort, aber vor allem auch hinsichtlich Effizienzsteigerung und Kostensenkung niederschlagen.

Der traditionelle Ansatz stellt sehr hohe Anforderungen an das Schutzziel Verfügbarkeit. Damit Client-Server Infrastrukturen ausreichend gut skalieren, müssen ausreichende Serverkapazitäten vorgehalten werden, die auch Reserven für Stoßzeiten vorhalten. Durch die klassische, zentralisierte Struktur besteht die Gefahr von Single Point of Failures, die immer dann auftreten, wenn zentral vorgehaltene Ressourcen ausfallen. Um die Gefahr von Single Point of Failures zu minimieren,

müssen zusätzlich weitere Server an verschiedenen Standorten aufgestellt werden. Dadurch erhöht sich die Komplexität der gesamten Infrastruktur.

Aus der technischen Perspektive betrachtet, handelt es sich bei Client-Server Infrastrukturen um ein Relikt aus der Zeit, in der nur wenige Kommunikationsteilnehmer über große Mengen an Ressourcen verfügten. Aus diesem Grund verlangen diese Infrastrukturen dem Server die Hauptlasten ab, während die Clients ihre Anfragen mit relativ wenig Ressourcenaufwand bewältigen können. Bedingt durch die Fortschritte in der Computertechnik verfügen mittlerweile erhältliche, eingebettete Systeme über immer mehr Kommunikationsmöglichkeiten.

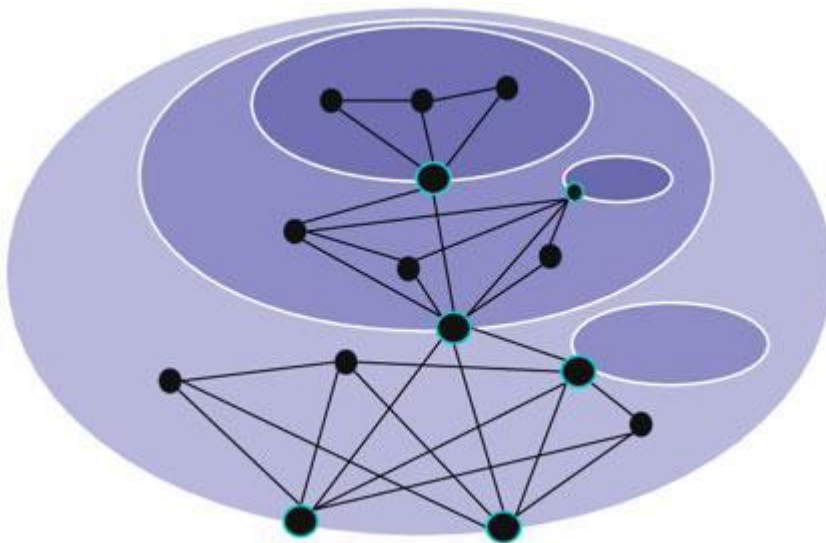


Abbildung 19: Konzept von dezentraler Infrastruktur

Auf Basis der erweiterten Möglichkeiten durch gestiegene Ressourcen auf den Clientsystemen, wurde eine neue Klasse von Kommunikationsinfrastrukturen entwickelt. Bei den so genannten Peer-to-Peer Verfahren wird die stringente Client-Server Kommunikationshierarchie aufgebrochen. Jeder Teilnehmer der Kommunikationsinfrastruktur nimmt für die verwalteten Daten zugleich die Rollen des Servers und des Clients ein. Wenn ein Teilnehmer Datensätze benötigt, wird über das Kommunikationsprotokoll der Teilnehmer ausgewählt, der über die aktuellen Daten verfügt und nach vordefinierbaren Qualitätsmaßstäben der optimale Anbieter ist. Ausfälle einzelner Teilnehmer, Überlastungen oder unvollständige Synchronisationen haben auf Peer-to-Peer-Systemen nur geringe Auswirkungen, da stets redundante Systeme vorhanden sind.

Im IUNO-Projekt wurden in Form eines Baukastens robuste Methoden und Technologien identifiziert, die dem aktuellen Stand entsprechen und durch dezentrale Ansätze, insbesondere das in der Industrie wichtige Schutzziel Verfügbarkeit, adressieren.

Das Client-Server Modell wird durch ein dezentrales Kommunikations-Modell ersetzt. Mit modernen Routing-Techniken werden Ende-zu-Ende Verbindungen ermöglicht. Die Kommunikationspartner werden eindeutig mit kryptographischen Verfahren identifiziert.

Ausblick

Wie wirkt sich die Arbeit in diesem Anwendungsfall auf zukünftige Themen in Industrie 4.0 aus?

Das Forschungsprojekt hat gezeigt, dass notwendige (Teil-)Lösungen für die Produktionsumgebung am Markt noch nicht bestehen. Im Rahmen von IUNO wurde daher ein IT-Sicherheitsleitstand für die Produktion konzipiert und erfolgreich als Demonstrator erprobt. Auf Basis der definierten Architektur wurden Komponenten und Schnittstellen festgelegt, die im Rahmen der Bedrohungs- und Risikoanalyse untersucht wurden. Damit wurde die Eintrittswahrscheinlichkeit und die Schadensschwere von Angriffen und Sicherheitslücken für den Leitstand als solches weitestgehend minimiert. Zeitgleich waren diese Analysen die Ausgangslage für das Konzept und die Umsetzung. Somit können die einzelnen Phasen und Schritte des Vorhabens jederzeit von Dritten nachvollzogen und reproduziert werden.

Das Resultat „Visueller Security Leitstand“ zeigt auf, dass Datenströme in der Produktion in Echtzeit erfasst und der aktuelle Stand der Informationssicherheit ganzheitlich und übersichtlich abbildbar ist. Abweichungen der Produktionsumgebung sind damit identifizier- und detektierbar. Damit sind Unternehmen nun erstmalig umfassend in der Lage einen Angriff in einer Produktionsumgebung schnell zu erfassen und in den Prozess eingreifen zu können. Damit konnte der Stand der Technik gehoben werden und die Erfassung, Analyse und Übermittlung von benötigten sicherheitsrelevanten Daten eines Produktionsnetzes verwirklicht werden. Damit liefert das IUNO Projekt „Visueller Security Leitstand“ einen westlichen Beitrag zur ganzheitlichen Sicherheit im Kontext von der Vision Industrie 4.0.

Welche Verbesserungen sind notwendig und welcher Forschungs- und Entwicklungsbedarf besteht?

Trotz der weitreichenden Forschungsergebnissen und der Verbesserung der Detektion von Angriffen in einer Produktionsumgebung ist der Ansatz, insbesondere für KMUs, noch nicht in der Breite anwendungstauglich. Die Umsetzung erfordert trotz umfangreicher Dokumentationen notweniges Know-how und birgt daher aktuell hohe Investitions- und Betriebskosten. Der erforschte Ansatz ist daher in Richtung einer leicht integrierbaren Lösung, einem sogenannten Lösungsbaustein, weiterzuentwickeln. Damit soll es den KMUs erleichtert werden den Ansatz in der eigenen Produktionsumgebung zu implementieren und in Betrieb zu nehmen. Darüber hinaus sind Werkzeuge zu entwickeln, die diese Prozesse unterstützen.

Weiterhin besteht der erhöhte Bedarf Kunden und Lieferanten in ein derartiges Sicherheitskonzept einzubinden. Die vielfältigen und teils sehr komplexen Produktionsinfrastrukturen erschweren derzeit eine derartige Einbindung mit unterschiedlichen Kommunikationspartnern. Eine Standardisierung der Kommunikation, Zonierung und benötigter Schnittstellen könnte hier künftig Abhilfe verschaffen. Auch in Hinsicht der Angriffserkennung besteht weiterhin Forschungsbedarf. In der IUNO-Versuchsumgebung des „Visuellen Security-Leitstandes“ erfolgt die Detektierung von Angriffen mit Hilfe exemplarischer Angriffe. Künftig gilt es jedoch eine Vielzahl von Angriffsarten und -Mustern erkennen zu können. Dafür sind weitere Forschungstätigkeiten notwendig. Vielversprechend ist dabei der Ansatz der Künstlichen Intelligenz bzw. des Machine Learnings. Leitstände müssen in die Lage versetzt werden, neue und angepasste Angriffsmethoden schnellstmöglich und eigenständig erkennen zu können. Dabei steht die Verknüpfung von Leitständen im Mittelpunkt. Standardisierte Integritätsreferenzwerte könnten in einem Netz global vernetzter Leitstände die Überwachung und den

Austausch von Anomalien deutlich verbessern. Der Einsatz von Distributed Ledger Technologien bietet schon heute vielversprechende Ansätze hierfür, die sind diese größtenteils noch unerforscht.

Referenzen

S. Plaga, S. Tatschner und A. Giehl. „AP2 – Securityanforderungen“. In: IUNO – Nationales Referenzprojekt für Industrie 4.0 (2016).

N. Wiedermann und A. Giehl. „AP2 – Securityanforderungen Addendum“. In: IUNO – Nationales Referenzprojekt für Industrie 4.0 (2017).

G. Hansch, P. Schneider und S. Plaga. "Packet-wise compression and forwarding of industrial network captures." 2017 9th IEEE International Conference on Intelligent Data Acquisition and Advanced Computing Systems: Technology and Applications (IDAACS), Vol. 1. IEEE, 2017.

SDL-Tool: <https://www.microsoft.com/en-us/sdl/adopt/threatmodeling.aspx>

[P4] The P4 Language Consortium, P4 16 Language Specification, Version 1.0.0, 22.05.2017, <https://p4.org/p4-spec/docs/P4-16-v1.0.0-spec.pdf>

[OpenFlow] Open Networking Foundation, OpenFlow Switch Specification, Version 1.0.0, 31.12.2009, ONF TS-001, <https://www.opennetworking.org/software-defined-standards/specifications>

[PoX] McCauley, Scott, Wundsam, Guedes et al., Pox OpenFlow Controller, <https://github.com/noxrepo/pox>

[D4.2] Ricardo Hormann, Stephan Teuber et al., Deliverable 4.2-1 / M24 - Anomalieerkennung im Wertschöpfungsnetzwerk; Datenaustauschplattform für das Wertschöpfungsnetzwerk, 30.06.2017

[TatSu] Juancarlo Añez et al., 竜 TatSu grammar compiler, <https://tatsu.readthedocs.io/en/stable/index.html>

[GCC] Richard M. Stallman et al., The Gnu Compiler Collection, <https://gcc.gnu.org/>